STANDARD OPERATING PROCEDURE (SOP)

SIEM MITRE ATT&CK Integration Rule Set Implementation Guide

SOP ID	SOC-SIEM-MITRE-001	Version	1.0
Status	Draft	Environment	SOC.lab
Platform	Wazuh	Department	Security Engineering / SOC Operations
Owner	Security Engineering and SOC Engineering	Date	2026-03-16

1. Purpose

This SOP defines the standard process for implementing, maintaining, and validating a Wazuh rule set that maps detections to the MITRE ATT&CK framework for SOC.lab.

The objectives are to:

- Map Wazuh detections to ATT&CK tactics and techniques.
- Standardize rule creation and ATT&CK tagging.
- Improve detection coverage for exfiltration and policy-related security events.
- Support rule testing, tuning, and lifecycle management.
- Provide repeatable guidance for detection engineering in a professional SOC environment.

Wazuh rules and dashboards can surface ATT&CK context when the technique IDs are preserved directly in custom rule definitions.

2. Scope

This SOP applies to Wazuh-based detection engineering in SOC.lab for Windows and Linux telemetry sources, custom Wazuh rules, rule tuning, and ATT&CK-mapped detections used for rule base setup, testing, and operations.

This SOP covers:

- Rule intake and design.
- ATT&CK mapping standards.
- Custom rule authoring.
- Rule testing and validation.
- Deployment and change handling.
- Review cadence.
- Sample implementation patterns.

This SOP does not replace incident response playbooks, case handling procedures, or executive reporting standards. It is an implementation guide for the rule base.

3. Roles and Responsibilities

Role	Responsibilities
3.1 Security Engineering	• Owning the ATT&CK integration standard. • Authoring and approving new custom rules. • Defining severity logic based on threat impact. • Maintaining rule quality and tuning standards. • Reviewing ATT&CK technique alignment.

3.2 SOC Engineering	• Implementing approved rules in Wazuh. • Maintaining decoder and ruleset structure. • Testing rule logic. • Restarting services when required. • Validating dashboard and alert output.
3.3 SOC Analysts	• Validating alert usefulness. • Reporting false positives and false negatives. • Confirming mapped ATT&CK context is operationally useful. • Recommending tuning changes.
3.4 IT / Platform Operations	• Maintaining telemetry availability. • Preserving log pipeline health. • Assisting with source onboarding and normalization.

4. Governance Standard

4.1 ATT&CK Version Standard

SOC.lab will use the latest approved ATT&CK version at the time of quarterly review.

Rules do not need to be rewritten for every ATT&CK release, but mappings must be reviewed for deprecated techniques, replaced sub-techniques, technique name changes, and changed operational meaning.

4.2 Rule Ownership

Every custom rule must have a technical owner, a use-case category, a mapped ATT&CK technique where applicable, a review date, and a testing record.

4.3 Review Cadence

The rule set must be reviewed quarterly for ATT&CK alignment and additionally after significant telemetry changes, false-positive spikes, control changes affecting detections, or major Wazuh version changes.

5. Rule Design Principles

5.1 Mapping Standard

Each custom detection should map to one primary ATT&CK technique or sub-technique. Additional mappings are allowed only when technically justified.

For SOC.lab, prefer sub-technique mapping where possible, avoid attaching multiple unrelated techniques to one rule, and use one detection for one dominant behavior.

5.2 Severity Standard

Severity is based on threat significance, not just event presence.

- Critical: confirmed or near-confirmed malicious behavior with direct exfiltration, credential theft, or major control bypass.
- High: strong malicious indicators or high-confidence precursor to exfiltration.
- Medium: suspicious behavior requiring analyst review.
- Low: policy, hygiene, or weak-signal events.
- Informational: telemetry only, no immediate action.

5.3 Default Detection Bias

SOC.lab will use a balanced approach: prioritize actionable detections, maintain meaningful ATT&CK coverage, tune aggressively when false positives create analyst fatigue, and do not suppress high-value detections solely to reduce alert counts.

5.4 Exception Handling

The following may remain outside ATT&CK mapping: infrastructure health alerts, platform maintenance alerts, pure policy or administrative notifications with no adversary behavior relevance, and experimental detections pending review.

6. Required Alert Metadata

Every ATT&CK-mapped rule should include, at minimum: rule ID, rule title or description, severity, source type, ATT&CK technique or sub-technique ID, ATT&CK tactic context in rule documentation, owner, test status, and deployment date.

SOC.lab requires severity as the mandatory enrichment field in operations, and ATT&CK metadata must be preserved in the rule definition for use in Wazuh ATT&CK views.

7. Telemetry and Data Source Requirements

Rules covered by this SOP must be based on approved SOC.lab telemetry. At a minimum, the implementation should use the log sources already selected for this environment during requirements definition.

Before writing a rule, detection engineers must confirm the source exists in Wazuh, fields are parsed, the event is stable enough to alert on, the event can be tested in lab conditions, and the source supports ATT&CK-relevant context.

If the source is not natively parsed, a custom decoder may be required before a reliable rule can be built.

8. Detection Lifecycle

8.1 Intake

A new detection request may originate from ATT&CK coverage gaps, analyst recommendations, incident lessons learned, policy monitoring requirements, exfiltration use-case expansion, or new log source onboarding.

8.2 Use-Case Definition

Before authoring a rule, define the behavior to detect, affected platform, expected log source, ATT&CK technique or sub-technique, severity, tuning constraints, and known benign causes.

8.3 ATT&CK Mapping

The engineer must map the rule to one primary tactic and one primary technique or sub-technique. Optional secondary references belong in supporting documentation only.

8.4 Rule Authoring

Wazuh rules are XML-based and trigger when specified conditions are met. The rules engine can match decoded fields, source and destination IPs, ports, regex, decoder category, and related rule logic.

8.5 Testing

All new rules must be tested before production deployment using manual lab simulation, replay of known-good or known-bad sample logs, and Wazuh rule testing.

8.6 Tuning

After initial test success, remove weak matches, narrow noisy conditions, confirm field specificity, and validate that no obvious benign flood source exists.

8.7 Deployment

Approved rules are added to the Wazuh custom rules location and moved through change control. Use custom rule IDs in the 100000–120000 range to avoid collisions with built-in rules.

8.8 Validation

After deployment, inject or reproduce the triggering event, confirm the intended rule fires, confirm the ATT&CK ID appears in the alert, confirm severity is appropriate, and confirm no unintended rules are superseding it.

8.9 Maintenance

Rules are maintained until they no longer serve a real use case, telemetry changes break field extraction, ATT&CK mapping changes materially, or the rule is replaced by a stronger detection.

8.10 Retirement

A rule may be retired when it has persistent low value, source telemetry is discontinued, the logic is replaced, or false positives cannot be controlled without killing utility.

9. Wazuh Implementation Standard

9.1 File Locations

- Use /var/ossec/etc/rules/local_rules.xml for minor additions.
- Use /var/ossec/etc/rules/ for larger custom rule sets.
- Use /var/ossec/etc/decoders/local_decoder.xml for simple custom decoder work.
- Use /var/ossec/etc/decoders/ for larger decoder sets.

9.2 ID Allocation

- 110000–110099: exfiltration detections.
- 110100–110199: policy monitoring detections.
- 110200–110299: Linux access and transfer detections.
- 110300–110399: Windows data movement detections.

9.3 Naming Convention

Rule titles should follow: [TACTIC] [Platform] [Behavior].

Examples: [Exfiltration] Windows Suspicious Archive Staging; [Exfiltration] Linux Bulk Data Transfer Tool Use; [Policy] Windows USB Storage Policy Violation.

9.4 Group Tags

Use stable Wazuh groups such as windows, linux, policy, exfiltration, custom, and source-specific group names where appropriate.

10. Testing Standard

10.1 Mandatory Tests

Every rule must have one positive test case, one negative test case, one tuning review, and one analyst review if severity is High or Critical.

10.2 Test Method

SOC.lab will use manual lab simulation as primary validation and wazuh-logtest for rule and decoder validation.

10.3 Restart Requirement

After saving changed decoder or rule files, restart the Wazuh manager before expecting live alerts from those modifications.

11. Metrics

SOC.lab should track percentage of custom rules mapped to ATT&CK, exfiltration tactic coverage count, false positive rate by rule, rules without test evidence, rules without owners, stale rules older than 90 days without review, percentage of High or Critical rules validated in lab, and policy alerts suppressed due to expected behavior.

12. Implementation Procedure

12.1 Identify Use Case

- Select a detection goal.
- Confirm source telemetry exists.
- Confirm there is a clear ATT&CK behavior to map.
- Decide target severity.
- Document expected benign edge cases.

12.2 Confirm Decoder and Fields

- Review sample raw logs.
- Use existing Wazuh alerts or wazuh-logtest to determine parsed fields.
- If parsing is weak or absent, create or adjust a decoder first.
- Re-test until fields are stable.

12.3 Author Rule

- Create a custom XML rule in the approved custom rules file.
- Place the rule in the correct rule family.
- Use a unique custom rule ID.
- Define matching conditions.
- Add MITRE mapping.
- Set severity.
- Write a clear analyst-facing description.

12.4 Test Rule

- Load the sample event into wazuh-logtest.
- Verify decoder match.
- Verify the correct rule fires.
- Verify only the intended rule fires.
- Document the result.

12.5 Deploy Rule

- Commit the rule into the custom rules location.
- Restart Wazuh manager.
- Reproduce the test event.
- Confirm the alert appears correctly in Wazuh.
- Validate MITRE visibility in dashboard and event output.

12.6 Tune Rule

- Review initial triggered events.

- Identify benign noise.
- Refine field matching.
- Lower or raise severity if warranted.
- Re-test and re-document.

13. ATT&CK Mapping Standard for SOC.lab

13.1 Primary Priority Tactic

Exfiltration.

13.2 Secondary Rule Category

Policy-oriented monitoring. These may be ATT&CK-mapped when they represent adversary-relevant control bypass or data movement behavior, but purely administrative policy alerts may remain outside ATT&CK.

13.3 Mapping Rule

Use a sub-technique when it genuinely matches behavior, use the base technique only when sub-technique evidence is not strong, and use one primary mapping per rule unless the event clearly expresses a multi-stage detection.

14. Sample Wazuh Rule Examples

These are starter examples, not final production logic.

14.1 Example 1 — Windows suspicious archive staging before exfiltration

```
<group name="windows,exfiltration,custom">
  <rule id="110001" level="10">
    <if_group>sysmon_event1</if_group>
    <field name="win.eventdata.image" type="pcre2">(?i)(7z|winrar|rar|tar|powershell\.exe)</field>
    <field name="win.eventdata.commandLine" type="pcre2">(?i)(\.zip|\.7z|Compress-Archive| -mx=| a
)</field>
    <description>[Exfiltration] Windows suspicious archive creation or staging activity on
$(win.system.computer).</description>
    <mitre>
      <id>T1560</id>
    </mitre>
    <group>attack,exfiltration,windows,custom,</group>
  </rule>
</group>
```

Intent: Detect likely data staging into archives before transfer.

Notes: Tune heavily for admin tooling and backup workflows.

14.2 Example 2 — Linux bulk outbound transfer tool usage

```
<group name="linux,exfiltration,custom">
  <rule id="110101" level="9">
    <if_group>syslog,sshd</if_group>
    <match>scp|rsync|sftp|curl|wget</match>
    <description>[Exfiltration] Linux system observed file transfer tooling associated with outbound
data movement.</description>
    <mitre>
      <id>T1048</id>
    </mitre>
    <group>attack,exfiltration,linux,custom,</group>
  </rule>
</group>
```

Intent: Flag transfer tool activity where context suggests data movement.

Notes: In production, prefer decoded fields, user, destination, process ancestry, and path context rather than broad keyword-only matching.

14.3 Example 3 — Windows policy alert for USB storage control violation

```
<group name="windows,policy,custom">
  <rule id="110201" level="6">
    <if_group>sysmon_event_registry</if_group>
    <field name="win.eventdata.targetObject" type="pcre2">(?i)USBSTOR</field>
```

```
    <description>[Policy] Windows USB storage related registry modification observed.</description>
    <group>policy,windows,custom,</group>
  </rule>
</group>
```

Intent: Policy monitoring rule for removable-storage related control changes.

Mapping: Leave unmapped unless you confirm adversary-relevant behavior and can justify the ATT&CK linkage.

14.4 Example 4 — ATT&CK mapping pattern from Wazuh syntax

Use the <mitre><id>...</id></mitre> structure inside the custom rule definition to preserve ATT&CK context in the alert output.

15. Validation Checklist

A rule is not production-ready until all are true:

- ☐ Use case documented.
- ☐ Source log confirmed.
- ☐ Decoder confirmed.
- ☐ Rule ID assigned.
- ☐ Severity assigned.
- ☐ ATT&CK mapping reviewed.
- ☐ Positive test passed.
- ☐ Negative test passed.
- ☐ Analyst review completed for major alerts.
- ☐ Deployment recorded.
- ☐ Post-deployment validation completed.

16. Troubleshooting

16.1 Rule does not fire

- Decoder did not parse the event.
- Wrong field name used.
- Regex too strict.
- Parent or prerequisite rule not matched.
- Rule file saved in wrong path.
- Wazuh manager not restarted.

16.2 Wrong ATT&CK context shown

- MITRE ID typo.
- Incorrect technique choice.
- Multiple rules matching and the wrong one winning.
- Stale dashboard data.

16.3 Excessive false positives

- Over-broad regex.
- Noisy admin tools.
- Backup or sanctioned transfer workflows.
- Shared service accounts.
- Poor platform scoping.

16.4 Decoder issue

- If the source log is not parsed correctly, fix decoding first and keep custom decoder copies in the user decoder directory instead of editing core files directly.

17. Change Control

All production rule changes must include:

- Reason for change.
- Rule owner.
- Test evidence.
- Severity rationale.
- ATT&CK rationale.
- Deployment date.
- Rollback note.

For larger rule families, maintain rules in separate custom files rather than piling everything into one local file.

18. Documentation Requirements

Each rule record must include:

- Rule ID.
- Title.
- Description.
- Author.
- Owner.
- Platform.
- Log source.
- ATT&CK mapping.
- Severity.
- False positive notes.
- Test evidence.
- Last review date.

19. Recommended Initial SOC.lab Rule Buckets

- Windows archive creation or compression staging.
- Linux bulk transfer tooling.
- Suspicious outbound copy from analyst or server zones.
- Removable media policy violations.
- Unauthorized data-handling utilities.
- Policy alerts for prohibited transfer behavior.
- IDS or IPS corroboration rules tied to outbound transfer events.

20. Approval

Role	Name	Date / Signature
Prepared by	Joshua Sartain	12/12/2025
Reviewed by	Christian Word	12/12/2025
Approved by	Engineering Team	12/12/2025